

Access Controls Policy

LAST UPDATED: AUGUST 18, 2026

This policy defines the access controls MĪZAN uses to limit access to production assets and consumer financial data. It applies to all systems that store, process, or transmit data obtained via Plaid, SnapTrade, or related providers, and to all personnel with administrative access to those systems.

1. Purpose

To ensure that access to production systems and consumer data is restricted to authorized personnel, granted on the principle of least privilege, monitored continuously, and reviewed periodically. This policy supports compliance with Plaid's End User Data Protection requirements and applicable data-protection laws (GDPR, CCPA).

2. Scope

- All production hosting and data-platform accounts (Vercel, Supabase, GitHub, Plaid Dashboard, SnapTrade Dashboard, Anthropic Console, Sentry, Resend).
- All consumer-data tables in the Supabase project — including `plaid_tokens`, `plaid_accounts`, `plaid_transactions`, `user_snaptrade`, `user_state`, `budget_entries`, `goals`, `messages`, `nav_usage`, and `audit_log`.
- All secrets and credentials used to authenticate to third-party APIs (Plaid client ID/secret, Supabase service-role key, SnapTrade consumer key, Anthropic API key, market-data provider keys, transactional email keys, at-rest encryption key).
- All personnel with administrative responsibilities. MĪZAN currently has one operator (Amaan Khan), so "personnel" refers to that single principal. The policy is written to scale as additional personnel are added.

3. Roles and Responsibilities

Role	Responsibility	Current holder
Policy Owner	Maintains, reviews, and approves this policy.	Amaan Khan
Access Approver	Reviews and approves new administrative access requests.	Amaan Khan
Access Reviewer	Performs periodic access reviews and audits.	Amaan Khan
Incident Responder	Investigates suspected access compromise.	Amaan Khan

Until separation of duties is operationally feasible, the operator holds all roles. Approval of one's own access is documented in writing in the audit record (operator email plus timestamp).

4. Access Provisioning

4.1 Administrative access

- New administrative access requires written justification, approval by the Access Approver, and enrollment of multi-factor authentication before activation.
- Administrative accounts use unique credentials per provider. Shared logins are prohibited.
- Service-role credentials are stored only in Vercel encrypted environment variables, scoped per environment, and never committed to source control or shared by email or chat.

4.2 Consumer access

- End users authenticate to MĪZAN via Supabase Auth (email + password) and receive a Supabase-issued JWT for the session.

- End users may enroll a TOTP-based multi-factor factor through the in-app account settings.
- Every authenticated request that touches consumer financial data validates the JWT server-side. Anonymous or invalid-JWT requests are refused before any data access occurs.

5. Role-Based Access Control (RBAC)

MĪZAN enforces RBAC at the database layer via Supabase Postgres Row-Level Security (RLS):

- Every table containing consumer data has RLS enabled, with policies restricting `SELECT`, `INSERT`, `UPDATE`, and `DELETE` to rows where `auth.uid() = user_id`.
- The public-facing application uses the Supabase anonymous (`anon`) key, which is subject to RLS.
- Server-side operations that must bypass RLS (token storage, cross-user maintenance) use the `service-role` key, which is stored in Vercel environment variables and never transmitted to the browser under any code path.
- Where a table must be written but never client-authored — such as the product usage counters — writes go through a `SECURITY DEFINER` function with no client write policy at all, so a caller cannot set an arbitrary value or attribute a write to another user.
- The operator's elevated role inside the application is gated by a `profiles.is_root` column, set only via direct SQL by the policy owner. Root status grants additional UI but does not bypass RLS-enforced ownership of consumer data.

6. Authentication Strength

- Multi-factor authentication is **required** on every administrative account.
- Passwords satisfy each provider's minimum complexity requirements. Operator passwords are stored in a reputable password manager and never reused across providers.
- Multi-factor authentication is offered to all end users via Supabase TOTP. Enrollment is voluntary today; enforcement before sensitive operations is on the policy roadmap.

- JWT sessions issued by Supabase Auth are short-lived and refreshed via the standard Supabase refresh-token flow.
- Repeated authentication failures from a single address trigger a temporary block, recorded in `security_events`.

7. Access Modification and De-Provisioning

- If a role changes or a principal departs, the Access Approver revokes administrative credentials for that principal within 24 hours: provider-side account deactivation, password rotation for any shared service accounts (none today), and rotation of Vercel environment variables touched by the departing principal.
- End users may revoke a specific session from the in-app Sessions panel or trigger a full sign-out, both of which invalidate the corresponding Supabase session(s).
- Account deletion by an end user is destructive: all rows referencing their `user_id` are removed via `ON DELETE CASCADE`, and Plaid access tokens are revoked via Plaid's `/item/remove` endpoint before deletion.

8. Periodic Access Reviews

- The Access Reviewer audits the list of accounts with administrative access at least **quarterly**, or whenever a material change in personnel or vendors occurs — whichever is sooner. The review is prompted automatically from this document's own review date rather than relying on memory.
- The review includes: confirmation that MFA remains active on every admin account, verification that no orphaned credentials exist, confirmation that Vercel environment variables match the documented inventory, and a sample inspection of `audit_log` rows from the prior period.
- The review is recorded as an entry in `audit_log` with action `access.review` and the date of the review.

9. Audit Logging

MĪZAN writes an append-only audit record for every security-relevant action, including (but not limited to):

- Sign-in success and sign-in failure
- MFA enrollment, verification, and unenrollment
- Password reset and email change
- Bank or brokerage connect and disconnect
- Session revoke and account deletion
- Force-refresh and other privileged operations

Audit entries include user ID, action, target, IP address, and user-agent. Audit data is retained for at least 12 months and is reviewed during incident investigations and the periodic access review.

10. Secret and Credential Management

- All API secrets are stored in Vercel encrypted environment variables, scoped per environment (Production, Preview, Development).
- No secrets are stored in source control. Repository hygiene is enforced via `.gitignore` entries for `.env*` files and runtime state files.
- An automated daily credential preflight verifies that required credentials are present and functional, so a misconfiguration surfaces as an alert rather than as a silent outage.
- Suspected secret exposure triggers immediate rotation via the relevant provider dashboard and a security incident review.

11. Incident Response for Access Compromise

1. Contain: revoke compromised credentials, rotate associated secrets, and force sign-out where applicable.
2. Investigate using Sentry, Vercel logs, Supabase access logs, and the `audit_log` table.
3. Notify affected users without undue delay and in accordance with applicable law.
4. Notify Plaid and SnapTrade where their systems or data are implicated.
5. Document the incident, remediation, and lessons learned.

12. Contact

Access or credential questions: khanstyle02@gmail.com.

© 2026 MĪZAN · Operated by Amaan Khan

[Privacy](#) [Terms](#) [Contact](#) [Security](#) [Access Controls](#) [Data Retention](#)